AI Security Audit Proposal

Template for enterprise engagements
Prepared by: Tyson Mandela, Twinthos
Valid until: [Date + 30 days]

Proposal: [Client] AI Agent Security Audit

Prepared for: [Client Name]
Prepared by: Tyson Mandela, Twinthos — Applied AI Security
Date: [Date]
Proposal ID: TWINTHOS-AI-SEC-[YYYYMMDD]-[NNN]

---

1. Executive Summary

[Client] has deployed [Langflow / CrewAI / LangChain / MCP servers / custom agent framework] in [production / development / multi-tenant] environments. As of October 2026, the AI agent security landscape has:

- **1,500+ AI-related CVEs** disclosed in 2026 alone (GTIG)
- **99.9% of fixable AI vulnerabilities remain unpatched** (Orca Security, July 2026)
- **200,000+ exposed MCP servers** with no authentication (April 2026 advisory)
- **CVE-2026-105740** (Langflow, CVSS 9.9) actively exploited in the wild
- **CVE-2026-92206** (CrewAI) unpatched zero-day with no vendor fix for 11 months

The risk is not theoretical. AI agents run with production permissions, read internal documents, and hold API keys. A single unpatched MCP vulnerability or prompt injection flaw can lead to full system compromise, data exfiltration, and regulatory exposure.

Twinthos proposes a [3-day / 5-day / 2-day] engagement to audit your AI agent stack, identify exploitable vulnerabilities, and deliver a remediation playbook with continuous monitoring setup.

Cost of Inaction: The Decision Hypothesis

The question is not whether your AI agent stack is vulnerable. The question is what it costs you when — not if — that vulnerability is exploited.

The math for [Client]

Scenario	Estimated cost
Data breach via agent RCE — attacker uses unpatched CVE to access production systems, customer data, or cloud credentials	£500,000–£5,000,000
Regulatory fine — NIS2, GDPR, DORA, or ISO 42001 non-compliance discovered post-incident	£200,000–£10,000,000
Operational disruption — agent workflows halted for forensic investigation and remediation	£50,000–£500,000
Intellectual property loss — proprietary agent configs, prompts, or workflows exfiltrated	Unquantifiable
Reputational damage — customer trust destroyed, churn, brand impact	Long-term revenue loss

The audit costs £8,000–£25,000. A single breach starts at £500,000.

Hypothesis: [Client] runs AI agents with production permissions, reads internal documents, and holds API keys. Given that 99.9% of fixable AI vulnerabilities remain unpatched (Orca Security, July 2026) and you have [N] agents in [production / development], the expected value of inaction is massively negative. This audit is the cheapest insurance policy you will ever buy.

What changes with this audit: - You know exactly which CVEs affect YOUR stack, not a generic list - You have a verified remediation path sized to your risk appetite - You can show your board/CISO a dated technical report with CISA KEV + EPSS + exploit evidence - You stop hoping and start knowing

---

2. Scope of Work

In Scope

Activity	Deliverable
Dependency audit	Full CVE cross-reference of your lockfile against CISA KEV, NVD, and AI-specific feeds
Framework audit	Security review of [Langflow / LangChain / LangGraph / CrewAI / custom] configuration
MCP server inventory	Catalog of all MCP servers, tools, and permissions; allowlist policy
Prompt injection testing	Canary prompts against all agent workflows to test injection resistance
Sandbox / isolation review	Review of Code Interpreter, Docker, and runtime isolation configurations
Network egress review	Baseline of agent outbound connections; identify anomalous destinations
Credential exposure review	Audit of API keys, database passwords, and cloud tokens accessible to agents
Continuous monitoring setup	Twinthos AI Security Sentinel configured for your stack with Telegram/Discord alerts
Remediation playbook	Prioritised action list with CVSS, EPSS, CISA KEV status, and fix instructions
Final report	Formal audit report with executive summary, technical findings, and compliance mapping

Out of Scope

- Penetration testing of production systems without written authorization
- Source code review of your proprietary agent implementations (available as add-on)
- Regulatory certification (SOC 2, ISO 42001, NIS2) — we provide the evidence, not the certification
- Fix implementation — we recommend and verify, your team implements

---

3. Approach

Day 1: Discovery

- Lockfile analysis using Twinthos AI Security Sentinel
- CVE correlation against CISA KEV, FIRST EPSS, and AI-specific vulnerability feeds
- MCP server inventory and configuration review
- Network egress baseline

Day 2: Adversarial Testing

- Prompt injection canary suite against all agent workflows
- Tool poisoning scan (MCPTox-style)
- Sandbox escape attempts (controlled, non-destructive)
- SSRF and path traversal probes against RAG/search tools

Day 3: Analysis & Reporting

- Vulnerability triage with CVSS, EPSS, and CISA KEV status
- Remediation playbook with priority order
- Continuous monitoring setup and test
- Final report delivery and 60-min debrief

---

4. Team

Tyson Mandela — Lead Auditor
- Founder, Twinthos
- Applied AI builder: agents, automation, adoption, systems
- Developer enthusiast ambassador
- Owner, HumanitAI CIC (AI safety education and digital inclusion)

- Experience: AI security auditing, simulation models, TypeScript/Next.js development
- GitHub: github.com/twinthos/ai-sec-sentinel

---

5. Pricing

Option	Engagement	Price	Timeline
A — Focused Audit	Single framework (Langflow OR CrewAI)	£8,000	3 days
B — Full Stack Audit	Multi-framework + MCP + lockfile	£15,000	5 days
C — Red-Team Lite	Full adversarial simulation + report	£25,000	2 days
D — Ongoing Monitor	Continuous CVE tracking + alerts	£750/month	Ongoing

Payment terms: 50% on acceptance, 50% on report delivery.
Expenses: None — all remote. On-site available on request (+ £2,000/day).
Cancellation: 7-day written notice. Work in progress billed at £1,500/day.

---

6. Why Twinthos

Competitor	Limitation
cve.now	Generic CVE feed — 90% noise, no AI-only filter
Snyk / Dependabot	No MCP-specific detection, no EPSS, no CISA KEV integration
Lakera Guard	SaaS only, no local-first option, no lockfile scanning
Protect AI	Focus on model supply chain, not agent framework RCE
Traditional pentest firms	No AI-specific methodology, no continuous monitoring

Twinthos differentiators: - **AI-only filter:** We only alert on vulnerabilities that affect AI/agent/MCP stacks - **CISA KEV + EPSS:** Every finding is enriched with exploitation status and

probability - **Lockfile-aware:** We scan your actual dependencies, not generic CVE databases - **Local-first:** The Twinthos AI Security Sentinel runs on your infrastructure, no data leaves your network - **Continuous:** We don’t deliver a PDF and leave — we set up ongoing monitoring with Telegram/Discord alerts

---

7. Case Study: Langflow MCP Security

Context: Langflow has CVSS 9.9 RCE in its MCP stdio transport (CVE-2026-105740). 1,423+ exploitation attempts from 27 IPs across 15 countries since September 2026.

Twinthos approach: 1. Lockfile scan of standard Langflow deployment — identified 3 AI-related CVEs 2. MCP stdio transport configuration audit — confirmed unauthenticated access path 3. Environment variable injection test — demonstrated credential exfiltration via MCP 4. Remediation playbook — stdio disable, allowlist policy, network isolation

Deliverable: 12-page audit report with CVE cross-reference, exploitation path diagrams, and step-by-step remediation.

Outcome: [Client] implemented allowlist policy and disabled stdio transport. Zero incidents in 30 days post-remediation.

---

8. Next Steps

1. **Sign proposal** — return countersigned copy
2. **Schedule kickoff** — 30-min call to confirm scope and access
3. **Provide access** — lockfile, MCP config, agent definitions (read-only)
4. **Audit week** — Days 1-3 as described above
5. **Report delivery** — Day 3 end of business
6. **Debrief call** — 60-min walkthrough of findings and priorities

Estimated start date: [Date + 3-5 business days]
Completion date: [Start date + 3-5 days]

---

9. Acceptance

This proposal is valid for 30 days from the date above.

Authorised by: _____
Name: _____
Title: _____
Date: _____

Return to: tyson@twinthos.com

Twinthos is an applied AI security practice based in Bath, UK. We build and operate AI agents for enterprises, and we audit the security of AI agent stacks. Our open-source Twinthos AI Security Sentinel is available at github.com/twinthos/ai-sec-sentinel.